Resolución del cuestionario de estudio

Seguridad y Auditoría

n1krov, Juani, Pollo y Chipancho

4 de noviembre de 2026

Índice

1. PARTE I: Seguridad de SI/TI **2**
- 1.1. ¿Qué cuestiones determinan el management de los SI de un modo "seguro"? . . . 2
- 1.2. ¿Qué es la pérdida de seguridad? Cuando esta ocurre, ¿cuáles son los aspectos involucrados? 2
- 1.3. ¿Qué es la administración del riesgo? ¿Cómo se relaciona con la seguridad este concepto? 2
- 1.4. Enumerar y sintetizar las etapas de la administración del riesgo. . . . 3
- 1.5. ¿Cómo se clasifican las políticas de seguridad? . . . 4
- 1.6. ¿Qué es el delito informático? ¿Quiénes son los artífices del mismo y con qué modalidad operan? . . . 5

2. PARTE II: Auditoría de SI/TI **7**
- 2.1. ¿Qué es la auditoría de sistemas de información? . . . 7
- 2.2. ¿Qué es el control interno? Desarrolle las clasificaciones de control. Ejemplifique cada una. 7
- 2.3. ¿Cuáles son los tipos de prueba que se requieren en la Auditoría de SI? . . . 8
- 2.4. Para cada área de Auditoría determine: i. Concepto; ii. Funciones del Auditor; iii. Síntesis de los elementos a auditar. . . . 9
  - 2.4.1. Auditoría de la Función Informática (Organización y Administración del Ambiente Informático - Cap. 21) . . . 9
  - 2.4.2. Auditoría del Desarrollo de Sistemas (Cap. 23/25) *(incluye Adquisición de SW y Modificación de Programas - Cap. 26)* . . . 9
  - 2.4.3. Auditoría de Sistemas de Aplicación Instalados y Proceso de Datos (Cap. 25/26) *(incluye Control de Entrada de Datos)* . . . 10
  - 2.4.4. Evaluación de la Seguridad (Cap. 22, 23 y 24 + Continuidad de las operaciones) 10
  - 2.4.5. Evaluación de los Aspectos Legales de los Sistemas y de la Información . . . 11
- 2.5. Auditoría del desarrollo: efectúe un cuadro comparativo entre el enfoque de Lardent y el de Piattini & Del Peso. . . . 11

---

1. PARTE I: Seguridad de SI/TI

1.1. ¿Qué cuestiones determinan el management de los SI de un modo "seguro"?

Según **Robson (Cap. 13)**, administrar los SI/TI de un «modo seguro» está determinado por **tres aspectos que se superponen** (y que la organización debe demostrar que cumple, por ejemplo, ante una auditoría externa):

1. **«Seguros» desde un punto de vista organizacional / Técnico:** Uso de herramientas técnicas, fuentes de datos (formularios) y procedimientos internos de control para proteger los recursos.
2. **«Seguros» desde un punto de vista social / Ético:** Obligaciones morales sobre qué es lo correcto respecto del manejo y privacidad de la información.
3. **«Seguros» desde un punto de vista judicial / Legal:** Cumplimiento del marco legislativo y normativo vigente sobre el almacenamiento, procesamiento y recuperación de datos (que codifica la perspectiva ética de la sociedad).

1.2. ¿Qué es la pérdida de seguridad? Cuando esta ocurre, ¿cuáles son los aspectos involucrados?

- **Concepto de pérdida de seguridad:** Es *«la falla de los elementos de un sistema de información computarizado para realizar la función o brindar el o los servicios para los cuales estaba destinado»*.
- **Los 3 aspectos técnicos involucrados** (la pérdida de uno impacta en los demás):
    1. **Pérdida de Integridad / Precisión:** Destruye la capacidad de la empresa para confiar en sus datos o, en el peor de los casos, la deja con datos de precisión incierta.
    2. **Pérdida de Operatividad / Disponibilidad:** Destruye, total o parcialmente, la capacidad de la empresa para acceder a los datos, sistemas e información cuando se necesitan.
    3. **Pérdida de Confidencialidad:** Destruye la posesión exclusiva de los datos (acceso solo según el rol organizacional), provocando pérdida de poder y confianza.
- **Consecuencias involucradas en la pérdida total:**
    - **Pérdidas directas (consecuencias primarias):** Surgen de forma inmediata y directa de la falla (ej. interrupción del procesamiento, corrupción de registros, destrucción de medios, robo de equipos/datos).
    - **Pérdidas secundarias:** Surgen como consecuencia de las primarias a largo plazo; son costos empresariales más graves y difíciles de cuantificar (se miden cualitativamente: pérdida de confianza del cliente, retraso en entregas, sanciones legales, pérdida de posición competitiva o incapacidad de continuar el negocio).

1.3. ¿Qué es la administración del riesgo? ¿Cómo se relaciona con la seguridad este concepto?

- **Concepto de Riesgo y Administración del Riesgo:** El **riesgo** es el potencial de que una amenaza determinada explote las vulnerabilidades de un activo o grupo de activos y ocasione su pérdida o daño (ISACA). Está ligado a la **materialidad** (impacto monetario del error para la

organización). La **administración (*management*) del riesgo** es el enfoque sistemático para identificar, analizar y controlar la exposición al riesgo de cada elemento de los SI.

- **Relación con la seguridad (Premisas de cátedra y Equilibrio Óptimo):**
    1. **La seguridad total (100%) es imposible:** Solo se puede alcanzar un nivel razonable de seguridad.
    2. **No se administra la seguridad en sí, sino el nivel de riesgo:** Cuanto menor es el nivel de riesgo, mayor es la seguridad.
    3. **El Equilibrio Óptimo:** La administración del riesgo busca el **punto de equilibrio óptimo** (mínimo costo total para la empresa) entre: **(a) los costos de las medidas y controles necesarios para aumentar la seguridad** y **(b) los costos de los daños potenciales resultantes de no tomar precauciones (fallas de seguridad)**. No debe gastarse ni más ni menos que ese punto óptimo.

1.4. Enumerar y sintetizar las etapas de la administración del riesgo.

El *management* de la seguridad de SI se reduce a una metodología de **4 etapas genéricas**:

1. **Identificación del riesgo:** Encontrar todos los puntos débiles combinando el *personal interno* (profunda comprensión de la empresa) y *consultores externos* (amplio conocimiento técnico). Debe identificarse en **ORDEN ESTRICTO (A-V-A)**:
    - **1º Activos** vulnerables a proteger (*Hardware, Software, Datos e información [la pérdida más seria], Capacidad de procesamiento, Personal y Fondos*).
    - **2º Ubicación de los riesgos y Vulnerabilidades** potenciales (qué es atacable; depende del personal, tamaño de la red y calidad de transmisión).
    - **3º Fuentes de Amenazas** potenciales (condición con capacidad de daño; pueden ser **Físicas o Lógicas** y **Accidentales o Deliberadas**).
    - *(Además se distinguen el **Riesgo Global** y el **Riesgo Residual** que queda tras aplicar los controles).*
2. **Análisis del riesgo:** Etapa estructurada donde se asigna un valor monetario al impacto potencial y se estima su frecuencia para hallar la **Exposición Anual de Pérdidas (ALE)**:

$$\text{Frecuencia de pérdida} = \text{Probabilidad de agresión} \times \text{Probabilidad de éxito}$$

$$\text{Pérdida esperada (ALE)} = \text{Pérdida potencial (\$)} \times \text{Frecuencia de pérdida}$$

$$\text{Pérdida Total} = \text{Consecuencias Primarias} + \text{Consecuencias Secundarias}$$

3. **Manejo del riesgo:** Usar el resultado de la etapa 2 para elegir **una estrategia genérica por cada riesgo** (formando un *portfolio*):

- **Prevenir el riesgo:** Evitar que ocurra la amenaza (ej. antivirus, áreas protegidas).
- **Asumir el riesgo:** Afrontar la pérdida esperada cuando el costo total (primario + secundario) es tolerable.
- **Reducir el riesgo:** Implementar controles/contramedidas para achicar la probabilidad o las pérdidas (ej. *backups*).
- **Transferir el riesgo:** Trasladar el costo a un tercero mediante seguros o contratos (ideal para amenazas de **alto costo y baja probabilidad**).
- *Implementación:* Mediante **Políticas de Seguridad** y **Capas de Controles y Contramedidas** (*Generales vs. de Aplicación*; *Físicos vs. Lógicos*), estructuradas en **3 Líneas de Defensa**: **1.ª Prevención** y **2.ª Detección** (*Controles*: actúan **antes** del incidente) y **3.ª Recuperación** (*Contramedidas*: actúan **después** para mitigar y volver a la normalidad).

4. **Recuperación ante el desastre (Planificación de Contingencias):** Asume que la prevención total es imposible y define planes (responsabilidad de la gerencia superior) para sobrevivir y recuperarse según el **lapso crítico de recuperación**:
   - *Paso 1:* Clasificar los sistemas según su **grado de tolerancia a la interrupción**: **Críticos** (tolerancia muy baja, no reemplazables manualmente), **Vitales** (tolerancia moderada, reemplazo manual breve), **Sensibles** (tolerancia flexible) y **No críticos** (tolerancia amplia).
   - *Situaciones de interrupción (Lardent):* **Catástrofe** (destrucción física total de instalaciones), **Desastre** (interrupción $>$ 1 **día**, requiere ir a sede alternativa con copias *off-site* hasta reparar la sede original) y **No desastre** (interrupción breve $\leq$ 1 **día**).
   - *Recursos del Plan:* Prioridades de recuperación, acoplamiento manual, entrenamiento del personal, **telecomunicaciones** (rutas alternativas y diversificadas), redes de energía, copias *off-site* y **hardware alternativo**: propio duplicado o contratado en **Hot sites** (instalaciones de emergencia completas, activación inmediata), **Warm sites** (instalaciones intermedias semiequipadas, sin CPU central), **Cold sites** (solo espacio físico acondicionado sin equipos) o **Instalaciones móviles**.

1.5. ¿Cómo se clasifican las políticas de seguridad?

Una **política de seguridad** es una medida preventiva (1.ª línea de defensa) que define el conjunto de requisitos establecidos por los responsables del sistema indicando qué está permitido y qué no durante su operación. Documenta el análisis de riesgo y debe cubrir: *protección, valor, acceso y recuperación de la información.*

- **1. Clasificación según su grado de restricción (Tipos):**
  - **Política Prohibitiva (Restrictiva):** *«Todo lo que no está expresamente permitido está prohi bido/denegado»*. Es mucho más restrictiva y **más efectiva en cuanto a seguridad** (ej. al servidor solo entran Juan y Pedro).
  - **Política Permisiva:** *«Todo lo que no está expresamente prohibido está permitido»*. Da mayor libertad pero menor seguridad (ej. prohibido tomar mate en el laboratorio $\rightarrow$ entonces sí puedo tomar café o gaseosa).

- **2. Clasificación según su amplitud (Niveles):**
  - **Políticas Generales:** Lineamientos amplios para toda la organización.
  - **Políticas Específicas (o de aplicación específica):** Refinan la política general en reglas precisas para cada activo, situación o perfil de usuario (ej. atención al cliente no puede cambiar el estado de un cliente, solo el jefe).
- **Complemento clave (Objetivos, Jerarquía y Ciclo de vida):**
  - *Los 6 elementos que toda política busca proteger:* **Disponibilidad, Utilidad, Integridad, Autenticidad, Confidencialidad y Posesión**.
  - *Pirámide normativa que la sustenta:* **1. Política** (principios generales obligatorios, pocas y de largo plazo; no cumplirla exige aprobar una excepción) → **2. Estándar/Norma** (regla obligatoria que especifica qué hacer) → **3. Mejor práctica** (configuración óptima específica de una plataforma aceptada por la industria) → **4. Procedimiento** (paso a paso de *cómo* implementarla en un área) → **5. Guía** (recomendación/sugerencia no obligatoria).
  - *Ciclo de vida (4 fases):* **1. Desarrollo** (Creación, Revisión, Aprobación) → **2. Implementación** (Comunicación, Cumplimiento, Excepciones documentadas) → **3. Mantenimiento** (Concientización continua, Monitoreo, Garantía de cumplimiento y Mantenimiento por ser *contingente*) → **4. Eliminación** (Retiro por obsolescencia).

1.6. ¿Qué es el delito informático? ¿Quiénes son los artífices del mismo y con qué modalidad operan?

- **1. ¿Qué es el delito informático? (Piattini & Del Peso):**
  - *Definición exacta:* «Es toda acción (u omisión) culpable realizada por un ser humano que cause perjuicio a otras personas —sin que necesariamente se beneficie el autor— o que, por el contrario, produzca un beneficio ilícito a su autor aunque no perjudique de forma directa o indirecta a la víctima; está **tipificada por la ley**, se realiza en un **entorno informático** y está **sancionada con una pena**».
  - *Características:* La computadora puede ser el **medio/instrumento** (ej. estafa contable) o el **fin/objeto** (ej. sabotaje de BBDD). Son «delitos de cuello blanco» (sin violencia física, a distancia, en milisegundos y con alta complejidad probatoria).
- **2. ¿Quiénes son sus artífices (sujetos activos)?:**
  1. **Personal interno y ex-empleados (*Insiders*):** Estadísticamente son **la mayor fuente de riesgo** porque conocen los procedimientos, claves y debilidades del control interno (por eso es vital la *segregación de funciones*).
  2. **Hackers:** Expertos técnicos que burlan controles por desafío intelectual o curiosidad, en principio sin intención destructiva.
  3. **Crackers:** Sujetos con altos conocimientos que irrumpen con **fines maliciosos o de lucro ilícito** (destruir datos, robar, defraudar, desproteger software).
  4. **Phreakers:** Especialistas en vulnerar sistemas de telecomunicaciones y redes telefónicas para interceptar o usar servicios sin pagar.

5. **Piratas informáticos / Bucaneros:** Dedicados a la copia, reproducción y venta ilegal de software violando la propiedad intelectual.
6. **Lamers (*Script-kiddies*):** Usuarios sin conocimientos profundos que ejecutan virus o *scripts* armados por terceros.
7. **Espías industriales / Intrusos remunerados / Ciberterroristas:** Profesionales contratados para robar secretos, sabotear o extorsionar.

- **3. ¿Con qué modalidad operan? (En 2 niveles):**
  - **A. Modalidades generales de ataque al flujo de información:**
    - Se dividen en **Ataques Pasivos** (solo escuchan/monitorean el tráfico sin alterar datos; difíciles de detectar, se previenen con cifrado) y **Ataques Activos** (alteran el flujo o crean flujos falsos: *Suplantación de identidad, Reactuación/Repetición de mensajes, Modificación de mensajes y Degradación fraudulenta del servicio*), agrupados en **4 categorías**:
      1. **Interrupción** (contra la *Disponibilidad*: destruir hardware, cortar red).
      2. **Intercepción** (contra la *Confidencialidad*: pinchar líneas, copiar archivos).
      3. **Modificación** (contra la *Integridad*: alterar saldos o programas).
      4. **Fabricación** (contra la *Autenticidad*: insertar mensajes o registros falsos).
  - **B. Técnicas operativas específicas de fraude informático (Lardent):**
    - **Manipulación de datos de entrada (*Data Diddling*):** La más frecuente y sencilla; alterar o falsificar datos antes o durante su ingreso al sistema.
    - **Caballo de Troya (*Trojan Horse*):** Insertar instrucciones ocultas maliciosas dentro de un programa legítimo de uso habitual.
    - **Técnica del Salame (*Salami Technique*) y Redondeo por defecto (*Rounding Down*):** Sustraer pequeñas fracciones de centavos de miles de cuentas o liquidaciones hacia una cuenta propia.
    - **Llave Maestra (*Superzapping*):** Uso fraudulento de programas utilitarios de emergencia del sistema para modificar bases de datos saltándose todos los controles sin dejar rastro en los *logs*.
    - **Virus** (se autoduplican infectando archivos), **Gusanos** (se propagan y saturan redes sin requerir archivo anfitrión) y **Bombas lógicas o de tiempo** (código latente que se activa en una fecha o condición lógica).
    - **Puertas traseras o falsas (*Trap Doors / Backdoors*):** Accesos secretos dejados por programadores para saltar la autenticación.
    - **Ingreso a caballito de otro (*Piggy-backing*):** Aprovechar una sesión abierta o línea ya autorizada de un usuario legítimo.
    - **Ataque asincrónico:** Alterar datos mientras esperan en cola en líneas asincrónicas.
    - **Recolección de residuos (*Scavenging*) y Fuga de datos:** Buscar información en listados impresos desechados o en memoria/sectores de disco no borrados.

---

2. PARTE II: Auditoría de SI/TI

2.1. ¿Qué es la auditoría de sistemas de información?

- **Definición general de Auditoría (Cátedra):** Es la emisión de una **opinión** (*Contenido*) **profesional** (*Condición*) y **fundamentada en procedimientos** preestablecidos (*Justificación*) sobre una **información concreta recogida en cierto soporte / informe** (*Objeto*), cuya **finalidad** es determinar si dicha información presenta adecuadamente la realidad o cumple las expectativas de funcionamiento, rendimiento y **fiabilidad**.
- **Definición de Auditoría de SI según Lardent:** Es el componente de la Auditoría General que consiste en la **revisión sistemática y organizada de los sistemas en funcionamiento** para verificar si cumplen **5 propiedades**:
    1. **Vigencia** de los objetivos planteados como base del diseño original.
    2. **Concordancia** del sistema con los objetivos (**efectividad**).
    3. **Permanencia del diseño** por no haber sufrido alteraciones que lo degradaran operativamente.
    4. **Eficiencia** del sistema (relación costo-beneficio).
    5. **Seguridad** del sistema.

    – *Finalidad (Lardent):* Evaluar si la operatividad de los sistemas se realiza en forma efectiva (fiable) y segura según las normas internas y externas (ej. BCRA), asegurando pistas de auditoría (trazabilidad), controles de entrada, manejo de rechazos y autorización de cambios.
- **Definición según Piattini:** Es el proceso de recolección y evaluación de evidencias para determinar cuándo se **salvaguardan los activos** informáticos, cómo se mantiene la **integridad de los datos** y cómo se logran con **eficacia** los objetivos organizacionales y se usan con **eficiencia** los recursos.
- **Tipos según vínculo laboral: Auditoría Interna** (empleado con vínculo laboral, función asesora de *staff* sin autoridad de línea, reporta a la Dirección General, permanente/sistemática, informes de circulación interna) y **Auditoría Externa** (profesional independiente sin vínculo laboral, puntual, **da fe pública** y tiene implicancias legales/certificaciones).

2.2. ¿Qué es el control interno? Desarrolle las clasificaciones de control. Ejemplifique cada una.

- **Concepto de Control Interno:** Es cualquier actividad o acción, realizada **manual o automáticamente**, para prevenir, detectar o corregir errores o irregularidades que puedan afectar el funcionamiento de un sistema para cumplir sus objetivos. Comprende el plan de organización y las medidas adoptadas para: *1) Salvaguardar activos, 2) Verificar la confiabilidad y exactitud de los datos, 3) Promover la eficiencia operativa, y 4) Fomentar la adhesión a las políticas administrativas.*

    – *(Nota de Piattini: Como unidad organizativa, el **Control Interno Informático [CII]** es el departamento interno que controla **en el día a día** el cumplimiento de normas dentro del Departamento de Informática e informa al Director de Informática, sirviendo de insumo al Auditor).*

- **Clasificaciones de los controles y ejemplos:**

    1. **Según el momento en que actúan (Lardent - las 3 categorías centrales):**
        - **Controles Preventivos (1.ª línea de defensa):** Diseñados para **evitar** que se produzca un error, omisión o acto malicioso antes de que ocurra. *Ejemplo:* Software de control de acceso lógico (usuario y contraseña) que solo permite a usuarios autorizados entrar a archivos sensibles; o prohibir fumar en el centro de cómputos.
        - **Controles Detectivos o de Detección (2.ª línea de defensa):** Actúan cuando fallan los preventivos; **descubren e informan** que se ha producido un error, omisión o intrusión. *Ejemplo:* Software de seguridad que registra en un *log* los intentos de acceso no autorizado; o un detector de humo.
        - **Controles Correctivos (3.ª línea de defensa): Corrigen** los errores/omisiones ya producidos y buscan **restablecer/recuperar** el funcionamiento normal del sistema. *Ejemplo:* Un campo de formulario que coloca automáticamente la fecha actual si se ingresó mal el formato; o restaurar una base de datos dañada a partir de un *backup*.
    2. **Según su alcance en los sistemas (Robson):**
        - **Controles Generales:** Reducen amenazas sobre *todas* las actividades y sistemas de SI de la organización (ej. políticas de seguridad física del centro de datos o gestión de cambios).
        - **Controles de Aplicación:** Diseñados para proteger una aplicación o proceso específico (ej. validación de dígito verificador del CUIT al cargar una factura).
    3. **Según su naturaleza técnica:**
        - **Controles Lógicos:** Medidas de software y datos (ej. contraseñas, encriptación, *firewalls*).
        - **Controles Físicos:** Filtran el acceso físico al equipamiento (ej. guardias, cerraduras biométricas, tarjetas magnéticas).

2.3. ¿Cuáles son los tipos de prueba que se requieren en la Auditoría de SI?

Las **pruebas** son las *acciones o métodos* (el verbo) que ejecuta el auditor para obtener **evidencia** (el sustantivo: dato o documento que debe ser *Relevante, Fiable, Suficiente y Adecuada*). Se requieren **dos categorías de pruebas** (si el control interno es fuerte se priorizan las de cumplimiento; si es débil, las sustantivas):

1. **Pruebas de Cumplimiento (revisan «las reglas, el proceso y el papel»):**
    - *Objetivo:* Determinar si los controles realizados en el día a día **se ajustan a las políticas, manuales y procedimientos** definidos por la organización y si funcionan efectivamente. Su insumo principal es la **documentación**.
    - *Subclasificación:*
        - **Pruebas de detalles (más pasivas):** Revisión documental (ej. verificar en registros que la versión de un programa en producción coincida con el código fuente/objeto autorizado en la biblioteca).

- **Pruebas de observación e indagación (más activas):** Entrevistar al personal para ver si conoce el procedimiento de gestión de cambios y volver otro día para observar si realmente lo aplica; o simular el ingreso de datos erróneos para observar cómo responden los controles de edición.

2. **Pruebas Sustantivas o de Validación (revisan «los datos, resultados y sistemas a fondo»):**
    - *Objetivo:* Verificar directamente sobre el tratamiento de la información dentro del sistema si los datos son íntegros y exactos, y si los controles existentes **resisten intentos de fraude o alteración** (garantizan que el sistema hace lo que tiene que hacer). Utilizan herramientas informáticas.
    - *Ejemplos:* **Procesamiento en paralelo o cruzamiento de datos** (procesar la misma base de datos con la aplicación en dos servidores distintos y comparar que los resultados contables sean idénticos), verificar cómo y dónde se guardan las copias de seguridad o auditar el inventario físico de la biblioteca de cintas contra los registros.

2.4. Para cada área de Auditoría determine: i. Concepto; ii. Funciones del Auditor; iii. Síntesis de los elementos a auditar.

A continuación se detallan las áreas de la Auditoría de SI según la estructura de **Lardent** (síntesis de las 5 áreas de cátedra + desglose por capítulos del cuestionario):

2.4.1. Auditoría de la Función Informática (Organización y Administración del Ambiente Informático - Cap. 21)

- **i. Concepto:** Evalúa la estructura organizativa, las políticas y la administración del área de SI/TI para asegurar que los recursos informáticos estén bien gestionados, alineados con los objetivos del negocio y operando con un buen diseño de control interno y segregación de funciones.
- **ii. Funciones del Auditor:** Comprender el ambiente informático e identificar sus áreas funcionales; evaluar la estructura organizacional y su adecuación a las políticas; verificar la **segregación de funciones**; evaluar el ambiente de control interno y los niveles de autorización; analizar el nivel de formación/rotación del personal; efectuar pruebas de controles y detectar debilidades de gestión.
- **iii. Elementos a auditar:** Plan de organización (organigrama y división de responsabilidades), segregación de funciones en el departamento de sistemas, políticas y estándares de operatividad, formación del personal, funciones de proyecto/procesamiento/soporte técnico y el ambiente de control general.

2.4.2. Auditoría del Desarrollo de Sistemas (Cap. 23/25) *(incluye Adquisición de SW y Modificación de Programas - Cap. 26)*

- **i. Concepto:** Revisa los sistemas a lo largo de su ciclo de desarrollo (y cuando se compran a terceros o se modifican) para asegurar que cumplan con los requerimientos del usuario/negocio, sigan las metodologías establecidas e incorporen los **puntos de control** y **pistas de auditoría** necesarios para garantizar la calidad y confiabilidad del software.

- **ii. Funciones del Auditor:**
  - *En Desarrollo:* Determinar requerimientos básicos de usuarios; clasificar riesgos y exposiciones; identificar y asesorar en la incorporación de **puntos de control** y módulos/pistas de auditoría en el diseño; verificar que exista y sea consistente el **Estudio de Factibilidad** (técnica, económica y operativa); asegurar que se respete la metodología de desarrollo y participar en las pruebas. *(Quien audite luego el sistema en producción debe ser otra persona para mantener la independencia).*
  - *En Adquisición de SW:* Evaluar el proceso de compra, analizar la solvencia del proveedor, revisar contratos y mecanismos de **propiedad y recupero del código fuente**, soporte posventa y satisfacción de otros clientes.
  - *En Modificación de Programas:* Verificar que todo cambio esté autorizado, probado y documentado, auditando el control de bibliotecas (*librarian control*) y la concordancia entre código fuente y objeto.
- **iii. Elementos a auditar: 1) Ciclo de vida:** Plan Maestro de SI/TI, Estudio de Factibilidad, ERS, metodología/framework y cada fase (análisis, diseño lógico y físico, pruebas, implantación y posinstalación); **2) Documentación de sistemas** por etapa; **3) Adquisición de SW:** solvencia del proveedor, contratos, licencias y custodia del código fuente; **4) Modificación de programas:** registros de autorización, trazabilidad del cambio, pruebas y concordancia fuente-objeto.

2.4.3. Auditoría de Sistemas de Aplicación Instalados y Proceso de Datos (Cap. 25/26) *(incluye Control de Entrada de Datos)*

- **i. Concepto:** Evalúa los sistemas aplicativos que ya están en producción/operación (módulos de Ventas, Compras, Sueldos, etc.) y el procesamiento de datos y equipos, verificando sus fortalezas y debilidades para asegurar que solo ingresen datos completos, exactos, válidos y autorizados (una sola vez), que se procesen a tiempo según el diseño aprobado y que las salidas sean confiables.
- **ii. Funciones del Auditor:** Examinar la documentación para comprender cada aplicación y su flujo de datos; evaluar fortalezas y debilidades de los controles internos de la aplicación; ejecutar pruebas de cumplimiento y sustantivas sobre los controles de entrada, procesamiento, almacenamiento y salida (en entornos *batch*, en línea o distribuidos); analizar la eficiencia/eficacia operativa y verificar el cumplimiento de los objetivos gerenciales.
- **iii. Elementos a auditar: 1) Sistemas de entrada y captura de datos** (controles de validación, exactitud, integridad, autorización, manejo de rechazos/excepciones, *logs* y entrada remota); **2) Procesos y métodos de procesamiento de datos** y actualización de archivos/BBDD; **3) Controles de salida** y distribución de información; **4) Equipos y operaciones** del centro de cómputos.

2.4.4. Evaluación de la Seguridad (Cap. 22, 23 y 24 + Continuidad de las operaciones)

- **i. Concepto:** Rama especializada que verifica la eficacia de las medidas, políticas, normas y controles implementados para proteger la información crítica y los activos informáticos frente a amenazas internas y externas, abarcando: **a) Accesos Físicos y Lógicos (Cap. 22)**, **b) Seguridad**

en Bases de Datos (Cap. 23), **c) Seguridad en Redes y Sistemas Distribuidos (Cap. 24)** y **d) Continuidad de las Operaciones / Contingencia**.

- **ii. Funciones del Auditor:**
  - *En Accesos y General:* Evaluar el cumplimiento de políticas de seguridad y normas (ej. ISO 27001); probar controles de acceso físico y rutas de acceso lógico (claves, perfiles, límites de autorización); comprobar protección contra *malware/phishing* y protocolos de encriptación.
  - *En Bases de Datos:* Auditar la fiabilidad, disponibilidad, integridad y consistencia de la BBDD; revisar las funciones del DBA, los permisos por usuario/programa, los *logs* y los procedimientos de *backup* y recuperación.
  - *En Redes:* Revisar la seguridad física (cableado) y lógica de la LAN/WAN, los controles de transmisión (detección de errores, cifrado), el acceso remoto y los protocolos (TCP/IP).
  - *En Continuidad / Contingencia:* Evaluar la adecuación y actualización del **Plan de Contingencias** según la tolerancia de cada aplicación; examinar el inventario y la seguridad física de la sede alternativa; verificar cómo se fusionarán los datos de emergencia al reinstalar; revisar el contrato del *Hot/Warm/Cold site*, la capacitación del personal, los resultados de pruebas previas y las pólizas de seguro.
- **iii. Elementos a auditar:** Políticas de seguridad; controles de acceso físico (vigilancia, cerraduras, ubicación) y lógico (por etapas: prevención, detección, recuperación); sistemas de BBDD (*logs*, respaldos, rol del DBA); topología, dispositivos y comunicaciones de red; encriptación y antivirus; y el **Plan de Contingencias y copias de seguridad (*backups off-site*)**.

2.4.5. Evaluación de los Aspectos Legales de los Sistemas y de la Información

- **i. Concepto:** Verifica que el funcionamiento de los sistemas, el almacenamiento y tratamiento de datos y la adquisición/uso de tecnología cumplan estrictamente con el marco jurídico, regulatorio y contractual vigente.
- **ii. Funciones del Auditor:** Revisar el cumplimiento de leyes de protección de datos personales, propiedad intelectual, normativas de entes reguladores (ej. BCRA) y cláusulas contractuales con proveedores y empleados.
- **iii. Elementos a auditar:** Licencias de software instalado, contratos de desarrollo y *outsourcing* (SLA, confidencialidad, propiedad del código), cumplimiento de leyes de privacidad/delitos informáticos y normativas gubernamentales.

2.5. Auditoría del desarrollo: efectúe un cuadro comparativo entre el enfoque de Lardent y el de Piattini & Del Peso.

Criterio de Comparación	Enfoque de Alberto R. Lardent (Cap. 23, 25 y 26)	Enfoque de Mario Piattini y Emilio del Peso (Cap. 22)
1. Objetivo Principal	Identificar, analizar y evaluar los requerimientos del usuario, los riesgos y los **puntos de control** que deben incorporarse a los sistemas durante las fases de desarrollo para asegurar que cumplan con los requisitos del negocio.	Comprobar la existencia, correcta definición y aplicación de **procedimientos de control interno** basados en principios sólidos de **Ingeniería de Software**, determinando las deficiencias de control y los riesgos asociados.
2. Grado de Estructuración y Flexibilidad	**Más flexible y general:** Propone lineamientos y actividades generales a revisar sin imponer el «cómo» detallado; el auditor decide dónde poner el foco. Se adapta fácilmente tanto a metodologías clásicas como a **marcos ágiles**.	**Muy estructurado, técnico y prescriptivo:** Define procedimientos y guías paso a paso asociados a metodologías tradicionales en cascada derivadas de normas ISO (como **Métrica v3**), con herramientas y listas de verificación (niveles A a G).
3. Mirada y Foco Principal	**Enfoque institucional, administrativo y organizacional:** Pone la mirada en la productividad, la relación costo-beneficio (**Estudio de Factibilidad**), la alineación con el **Plan Maestro**, los contratos con proveedores y los aspectos normativos.	**Enfoque de Ingeniería de Software y Gestión («Doble foco»):** Combina la perspectiva técnica de calidad del software con la gestión organizativa para evitar altos costos de mantenimiento y el fracaso de proyectos (*crisis del software*).
4. Metodología de Auditoría utilizada	Se basa en definir e insertar **puntos de control clave** a lo largo de las fases del proyecto, junto con la incorporación de **módulos y pistas de auditoría** dentro del sistema para facilitar futuras revisiones de rutina.	Aplica formalmente la metodología de evaluación de riesgos de **ISACA**: parte de los riesgos potenciales y sigue el esquema jerárquico: N **Objetivos de Control** $\rightarrow N$ **Técnicas de Control** $\rightarrow$ **Pruebas de Cumplimiento**.

Criterio de Comparación	Enfoque de Alberto R. Lardent (Cap. 23, 25 y 26)	Enfoque de Mario Piattini y Emilio del Peso (Cap. 22)
5. Cobertura y División del Alcance	**Cobertura amplia en 4 niveles** (incluye etapas previas y posteriores): 1. **Revisión del ciclo de vida:** Parte del *Plan Maestro de SI/TI*, el *Estudio de Factibilidad* y recorre desde análisis de requerimientos hasta la **Posinstalación (mantenimiento)**. 2. **Auditoría de la documentación** por etapa. 3. **Auditoría de adquisición de SW** (solvencia del proveedor, contratos, recupero/propiedad del código fuente). 4. **Auditoría de modificación de programas** (autorización, trazabilidad, concordancia fuente-objeto).	**Cobertura acotada al desarrollo puro en 2 bloques («Doble foco»)** (abarca análisis, diseño, construcción e implantación, pero **excluye explotación, mantenimiento y retiro**, que trata en capítulos aparte): 1. **Auditoría de la organización y gestión del área de desarrollo** (cómo trabaja y se administra el personal: 8 objetivos de control divididos de la A a la G). 2. **Auditoría de proyectos de desarrollo de SI** (aprobación, planificación, gestión y calidad de cada proyecto según su riesgo y complejidad).
6. Rol del Auditor e Independencia	Cumple un **papel activo de consultoría/asesoría preventiva**, trabajando a la par del equipo durante el desarrollo para definir los puntos de control. **Por principio de independencia, la persona que luego audite el sistema en producción debe ser distinta de la que ayudó a definir los puntos de control.**	Actúa como una **función evaluadora e independiente** (aunque con rol asesor en recomendaciones) que verifica la existencia y el grado de cumplimiento de los objetivos y controles mediante pruebas de cumplimiento, muestreo y recolección de evidencias.